

Email Phishing Security Audit Report

Generated: 2026-09-21 14:42:05 | Audit Standard: RFC 5322 / SPF / DKIM

Executive Summary

Overall Verdict	HIGH RISK (Phishing Confirmed)
Calculated Risk Score	85 / 100 (Critical Action Required)
Target Subject	URGENT: Your Account Has Been Suspended - Action Required
Claimed Sender (From)	"PayPal Security Center" <security@paypal.com>
Actual Sender (Return-Path)	<attacker@scam-server.xyz>

Header Authentication Checks

Protocol / Test	Result	Technical Impact
Domain Spoofing Check	MISMATCH	Header 'From' domain does not align with 'Return-Path' domain.
SPF (Sender Policy Framework)	FAIL	Remote IP (192.0.2.1) is not authorized by paypal.com SPF record.
DKIM (DomainKeys Identified Mail)	FAIL	Cryptographic signature missing or altered in transit.

Detected Threat Vectors & Phishing Lures

- Direct Domain Spoofing:** The header claims to originate from paypal.com, but envelope sender routes to scam-server.xyz.
- Psychological Urgency Trigger:** Detected aggressive keywords (urgent, immediately, suspended, action required) designed to induce panic.
- Suspicious Raw IP URL:** Body contains embedded link directing to a raw internal/unverified IP (http://192.168.1.100/login-paypal-verify.html) bypassing standard DNS reputation filters.
- Suspicious TLD Usage:** Secondary link points to .buzz TLD, frequently leveraged in disposable phishing infrastructure.

Recommended Security Mitigation Actions

- Gateway Quarantine:** Add sender host and domain *.scam-server.xyz to the perimeter blocklist.
- Strict DMARC Policy:** Enforce a p=reject DMARC policy on outbound email gateways.
- User Warning:** Do not interact with links or attachments. Purge message from recipient inboxes across the tenant.